

AGEX Governance

1. 문서 개요

1.1 문서 목적

본 문서는 AGEX Governance의 구조, 원칙, 의사결정 체계, 정책 관리, Resource 승인, Agent 자율성 통제, Model 사용 통제, Plugin·Marketplace 관리, 데이터·Knowledge·Memory 관리, 비용·품질·보안 기준, 변경 관리, 책임 체계, 감사 및 예외 관리 기준을 정의한다.

AGEX에서 Governance는 운영자 승인 절차나 관리자 화면의 집합이 아니다.

AGEX는 Agent, Workflow, Model, Plugin, Knowledge, Memory, Runtime 및 Marketplace가 지속적으로 확장되고 서로 결합되는 AI Operating System이므로, 각 Resource와 실행이 어떤 조건에서 생성·승인·배포·활성화·변경·중단될 수 있는지를 Platform 수준에서 명확하게 통제해야 한다.

Governance는 다음 질문에 답할 수 있어야 한다.

- 누가 생성할 수 있는가.
- 누가 수정할 수 있는가.
- 누가 승인할 수 있는가.
- 무엇을 자동화할 수 있는가.
- 어떤 Action은 반드시 Human Approval이 필요한가.
- 어떤 Model을 어떤 데이터에 사용할 수 있는가.
- 어떤 Plugin과 Package를 허용할 것인가.
- 어떤 변경은 즉시 적용할 수 있는가.
- 어떤 변경은 Review와 Approval을 거쳐야 하는가.
- 품질과 비용은 어떤 기준으로 평가할 것인가.
- 보안 또는 정책 위반 시 무엇을 차단할 것인가.
- 예외는 누가, 언제까지 허용할 수 있는가.

본 문서는 AGEX 전체 Resource와 Runtime을 관리하는 최상위 운영·통제 기준으로 사용한다.

2. Governance의 공식 정의

AGEX Governance는 AI Resource와 AI 실행에 대한 권한, 정책, 승인, 품질, 위험, 비용, 변경, 감사 및 책임을 명시적으로 관리하여 AI의 자율성을 통제 가능한 운영 체계 안에 두는 Platform Governance Framework이다.

Governance는 단순한 사후 감사가 아니다.

Governance는 Resource가 생성되기 전부터 실행이 종료된 이후까지 전체 Lifecycle에 적용된다.

Design

- Create
- Validate
- Evaluate
- Review
- Approve
- Publish
- Activate
- Execute
- Monitor
- Audit
- Improve / Suspend / Retire

3. Governance 목표

AGEX Governance는 다음 목표를 충족해야 한다.

3.1 통제 가능한 자율성

Agent의 자율 행동 범위가 명시되어야 하며, 권한 없는 자율 실행을 방지해야 한다.

3.2 책임 추적

모든 주요 Resource와 Action에 Owner, Approver 및 변경 주체를 추적할 수 있어야 한다.

3.3 일관된 정책

보안·비용·품질·데이터·Model 사용 정책이 UI나 개별 Service별로 따로 구현되지 않아야 한다.

3.4 안전한 변경

Resource나 Policy 변경이 기존 실행을 예측 불가능하게 바꾸지 않아야 한다.

3.5 운영 투명성

어떤 Agent가 무엇을 실행했으며, 어떤 Model·Plugin·Knowledge를 사용했고, 어떤 Policy가 적용되었는지 확인할 수 있어야 한다.

3.6 위험 기반 통제

모든 Action을 동일하게 다루지 않고 Risk Level에 따라 승인, Audit, Sandbox 및 실행 제한을 차등 적용해야 한다.

3.7 품질 관리

AI Resource와 실행 결과가 정해진 품질 기준을 충족하는지 평가할 수 있어야 한다.

3.8 비용 관리

Agent·Workflow·Model·Plugin 사용 비용이 통제되지 않은 채 증가하지 않아야 한다.

3.9 생태계 신뢰

Marketplace와 Plugin 생태계가 신뢰 가능한 Publisher, Package 및 Version을 중심으로 운영되어야 한다.

3.10 지속적 개선

운영 결과와 Evaluation 데이터를 바탕으로 Resource와 Policy를 개선할 수 있어야 한다.

4. Governance 핵심 원칙

AGEX Governance는 다음 원칙을 따른다.

- Human Governed Autonomy
- Policy Before Execution

- Explicit Ownership
- Separation of Duties
- Risk-Based Governance
- Versioned Policy
- Immutable Published Resource
- Review Before Privilege Expansion
- Least Privilege
- Data Classification Driven
- Quality Before Promotion
- Cost Awareness
- Evidence-Based Approval
- No Silent Governance Change
- Exception with Expiration
- Continuous Monitoring
- Audit by Default for Sensitive Actions
- Emergency Control Available
- Platform Baseline Cannot Be Weakened
- Governance as Code Where Possible

5. Governance 적용 범위

Governance는 최소한 다음 영역에 적용한다.

1. Agent Governance
2. Workflow Governance
3. Model Governance
4. Knowledge Governance

5. Memory Governance
6. Plugin Governance
7. Marketplace Governance
8. Data Governance
9. Security Governance
10. Runtime Governance
11. Cost Governance
12. Quality Governance
13. Policy Governance
14. Change Governance
15. Tenant Governance
16. Administrator Governance
17. Package Governance
18. Incident Governance

6. Governance Layer 구조

AGEX Governance는 다음 계층으로 구성할 수 있다.

Platform Governance



Environment Governance



Tenant Governance



Namespace Governance



Resource Governance



Execution Governance

6.1 Platform Governance

AGEX 전체에 적용되는 최소 기준이다.

6.2 Environment Governance

Development, Staging, Production 등의 환경별 정책이다.

6.3 Tenant Governance

Tenant가 자체적으로 설정하는 운영 규칙이다.

6.4 Resource Governance

Agent, Workflow, Plugin 등 개별 Resource에 적용한다.

6.5 Execution Governance

실제 실행 순간에 적용되는 승인, 비용, 위험 및 정책 통제이다.

7. Governance Control Plane

Governance 관련 기능은 공통 Control Plane으로 관리해야 한다.

주요 구성요소:

- Policy Registry
- Policy Decision Engine
- Approval Manager
- Risk Engine
- Ownership Registry
- Evaluation Registry
- Compliance Rule Engine
- Exception Registry

- Governance Audit
 - Change Registry
 - Governance Dashboard
-

8. Governance Resource Model

Governance 자체도 공식 Resource로 관리한다.

주요 Resource:

- Policy
- Approval Policy
- Risk Policy
- Governance Rule
- Exception
- Review
- Approval
- Evaluation
- Owner Assignment
- Change Request
- Control Evidence
- Governance Decision

각 Resource는 Version과 Lifecycle을 가져야 한다.

9. Ownership

9.1 기본 원칙

모든 중요 Resource에는 명확한 Owner가 있어야 한다.

9.2 Owner 유형

- Individual
- Team
- Tenant
- Platform Function

9.3 Owner 역할

Owner는 다음 책임을 가진다.

- Resource 목적
- 최신성
- 품질
- 접근 범위
- Risk
- Deprecation
- 비용

9.4 Owner 부재

Owner가 없는 Resource는 Production Publish를 제한할 수 있다.

10. Responsibility Model

AGEX는 최소 다음 책임 역할을 구분할 수 있다.

- Creator
- Owner
- Reviewer
- Approver
- Operator
- Security Reviewer
- Auditor

- Publisher

10.1 역할 중복

낮은 위험 Resource는 일부 역할을 한 사람이 수행할 수 있다.

10.2 고위험 Resource

High 또는 Critical Resource는 역할 분리를 요구할 수 있다.

11. Separation of Duties

다음 행위를 동일 주체가 단독 수행하지 못하도록 정책을 설정할 수 있다.

예:

Create Critical Plugin

≠

Security Approve

≠

Publish Production

또는:

Change Security Policy

≠

Approve Security Exception

11.1 목적

- 내부자 위험 감소
 - 실수 방지
 - 승인 신뢰성 확보
-

12. Risk Classification

AGEX Resource와 Action은 Risk Level을 가진다.

권장 기본 등급:

- Low
- Moderate
- High
- Critical

12.1 Risk 평가 요소

- Data Sensitivity
- Permission Scope
- Side Effect
- Autonomy Level
- External Network Access
- Financial Impact
- Number of Users
- Tenant Impact
- Recoverability
- Irreversibility
- Model Uncertainty

12.2 Dynamic Risk

같은 Resource라도 실행 Context에 따라 Risk가 달라질 수 있다.

13. Risk Score

Risk Engine은 필요에 따라 정량적 Score를 계산할 수 있다.

예시 개념:

Risk Score =

Data Sensitivity

- + Permission Scope
- + Action Irreversibility
- + External Exposure
- + Autonomy Level
- + Impact Radius

정확한 계산식은 Governance Policy Version으로 관리한다.

14. Risk에 따른 통제

Low

- 자동 실행 가능
- 일반 Audit

Moderate

- 강화된 Monitoring
- 일부 Approval 가능

High

- Human Approval
- 제한된 Runtime
- 상세 Audit
- 비용 제한

Critical

- Mandatory Approval
- Separation of Duties
- Dedicated Runtime 가능
- 강화된 Security Review
- Emergency Kill Support

15. Autonomy Governance

AGEX의 Agent 자율성 수준은 Product Philosophy에서 정의한 공식 단계를 사용한다.

- L0: response only
- L1: propose plan
- L2: execute after approval
- L3: auto execute within restricted scope
- L4: continuous policy-based execution
- L5: multi-agent autonomous collaboration

15.1 기본 원칙

Autonomy Level은 Agent가 스스로 결정하지 않는다.

15.2 설정 주체

- Platform Policy
- Tenant Policy
- Agent Definition
- Execution Context

15.3 실제 자율성

실행 시 가장 제한적인 허용 범위를 적용한다.

16. Autonomy Level 변경

Agent를 L2에서 L4로 변경하는 것은 일반 설정 변경이 아니다.

다음 검토를 요구할 수 있다.

- Permission 확대 여부
- Tool 사용 범위
- Cost 변화

- Failure Impact
- Human Approval 감소
- Security Review

16.1 자동 확대 금지

운영 성공률이 높다는 이유만으로 Autonomy Level을 자동 상향하지 않는다.

17. Agent Governance

Agent Governance는 다음을 관리한다.

- Owner
- Role
- Goal
- Capability
- Permission
- Autonomy Level
- Model Policy
- Knowledge Scope
- Memory Policy
- Tool Scope
- Cost Limit
- Evaluation
- Lifecycle

17.1 Production Agent

Production Agent는 최소한 Validation과 Evaluation을 통과해야 한다.

17.2 High-Risk Agent

외부 Write, Privileged Action 또는 높은 자율성을 가진 Agent는 추가 Review를 요구한

다.

18. Agent Promotion Gate

Agent Lifecycle Promotion에는 Gate를 적용할 수 있다.

예:

Draft

→ Validation Gate

→ Evaluation Gate

→ Security Gate

→ Approval Gate

→ Published

18.1 Gate 결과

- Pass
- Fail
- Pass with Condition
- Require Review

19. Agent Evaluation Governance

Agent Evaluation은 다음을 포함할 수 있다.

- Task Success Rate
- Accuracy
- Tool Use Correctness
- Policy Compliance
- Hallucination Rate
- Cost

- Latency
- Recovery Rate

19.1 Evaluation Dataset

평가 Dataset 자체도 Version과 Owner를 가져야 한다.

19.2 평가 우회 금지

Production 배포를 위해 평가 결과를 임의 수정하지 않는다.

20. Workflow Governance

Workflow는 다음을 관리한다.

- Owner
- Version
- Trigger
- Step
- Permission
- Side Effect
- Approval
- Timeout
- Retry
- Compensation
- Cost
- Risk

20.1 Workflow Publish

모든 Dependency와 Permission이 검증되어야 한다.

20.2 Dynamic Workflow

실행 중 생성된 동적 Workflow도 Governance를 우회하지 않는다.

21. Workflow Change Governance

다음 변경은 높은 검토 대상이 될 수 있다.

- 신규 External Write Step
- Approval 제거
- Retry 증가
- Loop Limit 증가
- Privileged Plugin 추가
- Sensitive Knowledge 접근
- Autonomy 확대

21.1 변경 Diff

Review 화면에서 의미 있는 Diff를 제공해야 한다.

22. Model Governance

Model Governance는 다음을 관리한다.

- Provider
- Model ID
- Version
- Capability
- Data Handling
- Region
- Quality
- Cost
- Safety
- Availability

- Trust Level

22.1 Model Registry

승인된 Model만 공식 Runtime Routing에 사용할 수 있다.

22.2 Provider 승인

Provider와 Model 승인을 분리할 수 있다.

23. Model Trust Level

Model Provider는 다음과 같은 Trust Level을 가질 수 있다.

- Private
- Direct Approved
- Enterprise Approved
- Aggregator
- Restricted
- Blocked

23.1 Model 자체 평가

같은 Provider의 Model도 별도의 품질·안전 평가를 가져야 한다.

24. Model Admission Process

신규 Model의 운영 반영 과정:

Discover

→ Register

→ Capability Test

→ Quality Evaluation

→ Security Review

→ Data Policy Review

- Cost Evaluation
- Limited Release
- Approve
- General Availability

24.1 자동 등록 금지

Provider가 새 Model을 공개했다고 자동 Production 사용하지 않는다.

25. Model Routing Governance

Model Router는 다음 정책을 적용해야 한다.

Capability

- Tenant Policy
- Data Classification
- Provider Trust
- Region
- Quality Requirement
- Cost Budget
- Health
- Route

25.1 Cost 우선 금지

가장 저렴한 Model이 보안과 품질 기준을 위반하면 선택할 수 없다.

26. Model Fallback Governance

Fallback Group은 사전에 승인되어야 한다.

26.1 금지

Direct Approved Provider 장애 시 무조건 Aggregator Provider로 자동 전환하는 구조를

허용하지 않는다.

26.2 Fallback 조건

- Data Classification
- Region
- Provider Trust
- Tenant Policy
- Required Capability

모두 다시 평가한다.

27. Knowledge Governance

Knowledge Governance는 다음을 관리한다.

- Source
- Owner
- Trust Level
- Classification
- Version
- Freshness
- Quality
- Access
- Retention
- Citation

27.1 공식 Knowledge

Authoritative 또는 Verified 상태로 승격하려면 별도의 검증 절차를 요구할 수 있다.

27.2 Source 변경

원본 Source가 변경되면 영향 받는 Knowledge를 추적할 수 있어야 한다.

28. Knowledge Quality Governance

다음 지표를 사용할 수 있다.

- Source Accuracy
- Freshness
- Completeness
- Citation Quality
- Parsing Quality
- Retrieval Performance

28.1 Stale Knowledge

Freshness 기준을 초과하면 경고, Rank 하향 또는 사용 제한을 적용할 수 있다.

29. Memory Governance

Memory Governance는 다음을 관리한다.

- Write Policy
- Scope
- Retention
- Confidence
- Sensitive Information
- User Control
- Promotion
- Deletion

29.1 장기 Memory

Agent가 모든 Interaction을 자동 장기 저장할 수 없다.

29.2 Memory Promotion

User 또는 Agent Memory를 Tenant Memory로 확장할 때 별도 Governance를 적용한다.

30. Memory-to-Knowledge Governance

Memory가 Knowledge로 승격되는 표준 과정:

Memory

- Knowledge Candidate
- Source Validation
- Confidence Review
- Ownership Assignment
- Approval
- Knowledge Resource

30.1 자동 승격 금지

반복적으로 사용되었다는 이유만으로 공식 Knowledge로 자동 변경하지 않는다.

31. Plugin Governance

Plugin Governance는 다음을 관리한다.

- Publisher
- Version
- Permission
- Network
- Credential
- Side Effect
- Runtime
- Trust
- Vulnerability

- Marketplace Status

31.1 신규 Plugin

Production 사용 전 Manifest와 Security Validation을 통과해야 한다.

31.2 Permission 증가

Version Update로 Permission이 증가하면 재승인이 필요하다.

32. Marketplace Governance

Marketplace Governance는 다음을 관리한다.

- Publisher Verification
- Submission
- Package Review
- Certification
- Listing
- Pricing
- License
- Abuse
- Package Removal
- Emergency Block

32.1 Marketplace 등록

등록 가능 상태와 Runtime 사용 가능 상태를 구분한다.

32.2 Community Package

Tenant 정책에 따라 Production 설치를 제한할 수 있다.

33. Publisher Governance

Publisher는 다음 상태를 가질 수 있다.

- Registered
- Verified
- Restricted
- Suspended
- Blocked

33.1 위반 기록

Publisher의 보안.정책 위반 이력을 Trust 판단에 반영할 수 있다.

33.2 Publisher 차단

심각한 사고 시 신규 Publish 및 기존 Package 업데이트를 차단한다.

34. Data Governance

Data Governance는 다음을 관리한다.

- Ownership
- Classification
- Purpose
- Retention
- Residency
- Access
- Sharing
- Export
- Deletion

34.1 Data Owner

중요 데이터 Collection은 Owner가 있어야 한다.

34.2 Classification

Derived Data는 원본보다 낮은 등급으로 자동 하향하지 않는다.

35. Data Purpose Governance

데이터가 저장되었다는 이유만으로 모든 Agent가 이를 사용할 수 있는 것은 아니다.

Access Decision은 다음을 포함할 수 있다.

- Identity
- Purpose
- Resource
- Classification
- Execution Context

35.1 목적 외 이용

목적 제한 정책을 위반하는 Retrieval이나 Export를 차단할 수 있어야 한다.

36. Data Retention Governance

각 주요 Resource는 Retention Owner와 Policy를 가져야 한다.

대상:

- Knowledge
- Memory
- Execution
- Artifact
- Audit
- Logs

36.1 무기한 저장 금지

명확한 목적 없이 모든 데이터를 영구 보존하지 않는다.

37. Security Governance

Security Governance는 다음을 관리한다.

- Security Baseline
- Permission
- Security Policy
- Vulnerability
- Security Exception
- Incident
- Key/Secret Policy
- Trust Level

37.1 Baseline 변경

Platform Security Baseline 변경은 높은 수준의 Review와 Version 관리를 요구한다.

38. Runtime Governance

Runtime Governance는 다음을 관리한다.

- Runtime Version
- Worker Type
- Sandbox
- Resource Limit
- Execution Limit
- Network
- Kill Switch
- Compatibility

38.1 Runtime Admission

지원되지 않거나 취약한 Runtime Version은 신규 실행 대상에서 제외한다.

39. Cost Governance

AI OS에서는 비용이 운영 Risk의 일부이다.

Cost Governance는 다음을 관리한다.

- Budget
- Quota
- Token
- Model Cost
- Plugin Cost
- Compute
- GPU
- Marketplace Spend

39.1 Cost Owner

중요한 Tenant 또는 Application 영역에는 비용 책임 주체를 지정할 수 있다.

40. Cost Threshold Governance

예:

Budget 50%

→ Inform

Budget 80%

→ Warning

Budget 100%

→ Block / Approval Required

실제 Threshold는 Tenant 정책으로 설정한다.

40.1 Agent 예외 금지

Agent가 비용 때문에 자신의 Budget Limit을 변경할 수 없다.

41. Quality Governance

AGEX는 AI 품질을 단일 정확도 값으로만 평가하지 않는다.

평가 영역:

- Accuracy
- Relevance
- Consistency
- Groundedness
- Policy Compliance
- Reliability
- Latency
- Cost
- User Outcome

41.1 Resource별 품질

Agent, Model, Workflow, Knowledge, Plugin별로 적절한 품질 Metric을 정의한다.

42. Quality Gate

Production Promotion 전에 Quality Gate를 적용할 수 있다.

예:

Evaluation

→ Threshold Check

→ Regression Check

→ Risk Review

→ Approval

42.1 Regression

신규 Version이 기존 Version보다 주요 지표가 악화되면 Publish를 제한할 수 있다.

43. Human Approval Governance

Human Approval은 단순 버튼 클릭이 아니다.

Approval은 다음과 연결되어야 한다.

- Exact Action
- Exact Version
- Exact Payload 또는 Digest
- Resource
- Risk
- Requested By
- Expiration

43.1 승인 후 변경

Payload가 변경되면 기존 승인을 무효화해야 한다.

44. Approval Policy

Approval 요구 조건 예:

- High-Risk Plugin Action
- Irreversible Write
- Permission Expansion
- Critical Package Publish
- Production Security Policy Change
- Large Cost Execution

- Bulk Data Export

44.1 자동 승인

Low-Risk Action은 Policy에 의해 자동 Permit될 수 있다.

45. Approval State

- Requested
- Pending
- Approved
- Rejected
- Expired
- Cancelled
- Revoked

45.1 승인 만료

Approval은 영구적으로 재사용되지 않는다.

46. Policy Governance

Policy 자체도 Governance 대상이다.

46.1 Policy Resource

- Policy ID
- Name
- Owner
- Scope
- Version
- Rules
- Priority

- Lifecycle
- Approved By

46.2 Policy Lifecycle

Draft

→ Validate

→ Simulate

→ Review

→ Approve

→ Publish

→ Active

→ Deprecated

→ Archived

47. Policy Simulation

Production 활성화 전에 Policy가 실제 환경에 미칠 영향을 Simulation할 수 있어야 한다.

예:

- 몇 개 Agent가 차단되는가.
- 몇 개 Plugin이 비활성화되는가.
- 어떤 Model Routing이 변경되는가.

47.1 실제 권한

Simulation이 실제 권한이나 Policy State를 변경하지 않는다.

48. Policy Conflict

복수 Policy가 충돌하는 경우 우선순위 규칙을 명확히 정의해야 한다.

기본 개념:

Platform Security Baseline

>

Environment Policy

>

Tenant Policy

>

Namespace Policy

>

Resource Policy

48.1 Deny 우선

보안 관련 충돌에서는 명시적 Deny를 우선할 수 있다.

49. Policy Versioning

모든 주요 Policy는 Version을 가진다.

49.1 실행 기록

Execution에는 실제 적용된 Policy Version을 기록한다.

49.2 정책 변경

새 Policy 활성화가 기존 Execution에 영향을 주는지 유형별로 정의해야 한다.

49.3 긴급 Security Policy

긴급 차단은 기존 Snapshot보다 우선할 수 있다.

50. Change Governance

모든 변경을 동일하게 관리하지 않는다.

50.1 변경 유형

- Standard Change
- Normal Change
- High-Risk Change
- Emergency Change

50.2 변경 대상

- Resource Definition
- Policy
- Runtime
- Model
- Plugin
- Database
- Infrastructure
- Security Configuration

51. Change Request

중요 변경은 Change Request Resource를 사용할 수 있다.

필드:

- Change ID
- Requester
- Scope
- Reason
- Risk
- Impact
- Test Evidence
- Rollback Plan

- Approvers
 - Status
-

52. Change Diff

Governance Review는 단순 전체 문서를 보여주는 대신 의미 있는 Diff를 제공해야 한다.

예:

- Permission 추가
 - Model Provider 변경
 - Network 범위 확대
 - Workflow Step 추가
 - Cost Limit 변경
 - Retention 변경
-

53. Version Promotion

Resource Version은 환경 간 Promotion할 수 있다.

예:

Development

→ Testing

→ Staging

→ Production

53.1 재작성 금지

환경별로 동일 Version Definition을 임의 변경하지 않는다.

환경 차이는 Configuration과 Binding으로 처리한다.

54. Production Promotion Gate

Production Promotion은 다음 검증을 요구할 수 있다.

- Validation
- Test
- Evaluation
- Security
- Compatibility
- Cost
- Approval

54.1 Resource별 Gate

모든 Resource에 동일 Gate를 강제하지 않고 Risk Level에 따라 조정한다.

55. Exception Governance

보안·운영 정책 예외가 필요한 경우 Exception을 공식 Resource로 관리한다.

55.1 Exception 필드

- Exception ID
- Policy
- Scope
- Reason
- Risk
- Owner
- Approved By
- Start Date
- Expiration
- Compensating Control

55.2 만료 필수

예외는 기본적으로 Expiration을 가져야 한다.

55.3 영구 예외

극히 제한적으로만 허용한다.

56. Exception Review

Expiration 이전에 다음을 평가한다.

- 아직 필요한가.
- Risk가 증가했는가.
- 대체 Control이 생겼는가.
- 정상 Policy로 복귀 가능한가.

56.1 자동 만료

갱신 승인이 없으면 자동 만료되는 구조를 권장한다.

57. Governance Evidence

중요한 Governance Decision은 Evidence를 연결할 수 있어야 한다.

예:

- Test Result
- Evaluation Result
- Security Scan
- Penetration Test
- Cost Analysis
- Review Comment

57.1 Evidence 무결성

승인 이후 Evidence를 임의 교체할 수 없어야 한다.

58. Governance Decision Record

다음 결정을 기록할 수 있다.

- Approved
- Rejected
- Conditional Approval
- Suspended
- Exception Granted
- Exception Revoked

필드:

- Decision ID
 - Subject
 - Decision
 - Reason
 - Evidence
 - Decision Maker
 - Timestamp
-

59. Audit Governance

Governance 자체 행위도 Audit 대상이다.

예:

- Policy 변경
- Approval
- Exception
- Risk 변경
- Owner 변경

- Resource Promote
- Emergency Action

59.1 감사 독립성

감사 담당자가 감사 기록 자체를 변경할 수 있어서는 안 된다.

60. Governance Observability

Governance Dashboard는 다음을 제공할 수 있다.

- Pending Approvals
 - High-Risk Resources
 - Expiring Exceptions
 - Unowned Resources
 - Failed Evaluations
 - Policy Violations
 - Deprecated Models
 - Blocked Plugins
 - Budget Risks
-

61. Governance Metric

주요 Metric:

- Approval Lead Time
- Policy Denial Rate
- Exception Count
- Exception Expiration Rate
- High-Risk Resource Count
- Failed Promotion Rate

- Security Review Time
 - Model Approval Count
 - Plugin Rejection Rate
-

62. Governance Alert

Alert 예:

- Critical Exception Expiring
 - Owner Missing
 - Unapproved Permission Expansion
 - Blocked Model Used
 - High-Risk Agent Activated
 - Policy Bypass Attempt
 - Large Budget Overrun
 - Deprecated Package Still Active
-

63. Governance Automation

Governance의 반복 작업은 자동화할 수 있다.

예:

- Policy Validation
- Dependency Check
- Security Scan
- Version Compatibility
- Expiration Detection
- Owner Presence Check

63.1 자동화 제한

최종 책임 판단이 필요한 영역을 단순 Rule로 대체하지 않는다.

64. Governance as Code

정책과 주요 Gate를 Machine-Readable 형태로 정의할 수 있어야 한다.

장점:

- 재현성
- Versioning
- Testing
- CI/CD
- Audit

64.1 관리 UI

UI에서 변경하더라도 동일한 Policy Resource와 Version 체계를 사용해야 한다.

65. CI/CD Governance

CI/CD Pipeline에서 다음 Gate를 적용할 수 있다.

Build

- Unit Test
- Contract Test
- Security Scan
- Evaluation
- Governance Check
- Package
- Approval
- Deploy

65.1 Production Deploy

Pipeline Credential만으로 모든 Governance를 우회할 수 없어야 한다.

66. Runtime Governance Decision

Runtime은 실행 전에 최종 Governance Decision을 확인할 수 있다.

예:

Execution

→ Resource State

→ Tenant State

→ Policy

→ Risk

→ Approval

→ Budget

→ Runtime Admission

66.1 Published라도 실행 불가

Resource가 Published 상태라도 Tenant Policy 또는 Emergency Block으로 실행이 거부될 수 있다.

67. Governance Snapshot

Execution 시 적용된 Governance 상태를 기록한다.

예:

- Policy Version
- Approval ID
- Risk Level
- Resource Version
- Model Policy

- Permission Snapshot

67.1 재현성

나중에 왜 실행이 허용되었는지 설명할 수 있어야 한다.

68. Emergency Governance

보안 또는 운영 사고 시 일반 Governance 절차보다 긴급 통제가 우선할 수 있다.

68.1 Emergency Action

- Disable Agent
- Suspend Workflow
- Block Plugin
- Block Model
- Suspend Package
- Stop Runtime Pool
- Suspend Tenant

68.2 사후 검토

긴급 조치 후 반드시 Post-Event Review를 수행해야 한다.

69. Kill Switch Governance

Kill Switch 사용에는 다음을 기록한다.

- Actor
- Target
- Reason
- Timestamp
- Scope
- Recovery Condition

69.1 해제

Kill Switch 해제도 별도 승인 대상이 될 수 있다.

70. Incident Governance

Incident는 기술 장애와 Governance Failure를 함께 분석할 수 있어야 한다.

70.1 원인 예

- 잘못된 Policy
- Approval Failure
- 과도한 Permission
- Model 변경
- Plugin Vulnerability
- Cost Control Failure

70.2 개선

Incident 종료 후 Resource, Policy, Test 및 Governance Rule을 업데이트할 수 있다.

71. Governance Review Cycle

주요 Resource는 주기적으로 재검토할 수 있다.

대상:

- High-Risk Agents
- Critical Workflows
- External Plugins
- Sensitive Knowledge
- Model Providers
- Security Exceptions

71.1 주기

고정 주기는 운영 정책에서 정의한다.

Risk가 높을수록 짧은 Review Cycle을 적용할 수 있다.

72. Dormant Resource Governance

장기간 사용되지 않는 Resource를 탐지한다.

예:

- Agent
- Workflow
- Plugin Installation
- Secret
- Model Profile

72.1 처리

- Review
 - Disable
 - Deprecate
 - Archive
 - Delete
-

73. Deprecated Resource Governance

Deprecated Resource는 다음 정보를 가져야 한다.

- Deprecated Date
- Replacement
- End-of-Support
- Migration Requirement

73.1 신규 사용

정책에 따라 신규 Reference를 제한할 수 있다.

74. Tenant Governance

Tenant는 Platform Baseline 안에서 자체 Governance를 설정할 수 있다.

예:

- Agent 승인 정책
- Plugin Trust Level
- Model Provider
- Cost Budget
- Memory Policy
- Marketplace 설치
- Export Approval

74.1 Baseline 이하 금지

Tenant는 Platform Security Baseline을 약화시킬 수 없다.

75. Private Governance

Dedicated 또는 Private Deployment에서도 동일 Governance Contract를 유지하는 것을 원칙으로 한다.

75.1 Offline 환경

중앙 Control Plane 연결이 없어도 Local Policy, Approval 및 Audit가 동작해야 한다.

76. Governance Federation

향후 여러 조직 또는 독립 Control Plane 간 Governance Federation이 필요할 수 있다.

초기 Core에서 Cross-Tenant 권한 공유로 구현하지 않는다.

별도의 Federation Contract가 필요하다.

77. Administrator Governance

관리자 권한도 Governance 대상이다.

77.1 Privileged Operations

- Tenant Suspend
- Policy Override
- Secret Operation
- Package Block
- Bulk Delete
- Force Termination

77.2 통제

- MFA
- JIT Access
- Reason
- Audit
- Approval

78. Break-Glass Governance

비상 계정 사용 시:

- 명확한 사유
- 제한된 시간
- Alert
- 전체 Audit
- 사용 후 Credential Rotation
- Post-Use Review

를 적용할 수 있다.

79. Marketplace Commercial Governance

상업적 Marketplace에서는 기술 Governance 외에 다음도 관리한다.

- Pricing Integrity
- License
- Refund
- Publisher Settlement
- Misleading Claims
- Usage Measurement

79.1 가격과 기술 권한

결제 여부가 Security Permission을 대체하지 않는다.

80. AI Output Governance

모든 AI Output을 사전 승인해야 하는 것은 아니다.

Risk에 따라 다음을 구분한다.

- Informational Output
- Recommendation
- Draft Action
- Executable Action
- Irreversible Action

80.1 실행 가능한 Output

Model Output을 그대로 Action으로 간주하지 않고 Runtime Validation을 거친다.

81. Explainability Governance

고위험 Decision의 경우 최소한 다음을 기록할 수 있어야 한다.

- Input Sources
- Knowledge References
- Model
- Policy
- Selected Action
- Evaluation
- Human Approval

81.1 Raw Chain-of-Thought

설명 가능성을 위해 Raw Chain-of-Thought 저장을 요구하지 않는다.

82. Decision Traceability

최종 결과에서 다음 관계를 추적할 수 있어야 한다.

User / Event

→ Agent

→ Plan

→ Knowledge

→ Model

→ Plugin

→ Policy

→ Approval

→ Action

→ Result

83. Governance와 Audit의 차이

Audit는 "무엇이 일어났는가"를 기록한다.

Governance는 "무엇이 일어나도 되는가"를 결정한다.

둘은 별도 기능이지만 긴밀하게 연결되어야 한다.

84. Governance와 Security의 차이

Security는 접근·보호·격리를 중심으로 한다.

Governance는 다음까지 포함한다.

- 품질
- 비용
- Owner
- Approval
- Risk
- Lifecycle
- 책임

즉, Security는 Governance의 핵심 구성요소이지만 Governance 전체와 동일하지 않다.

85. Governance와 Policy의 차이

Policy는 기계적으로 평가 가능한 규칙이다.

Governance는 Policy뿐 아니라 다음을 포함한다.

- 인간 판단
- Review
- Approval
- Evidence
- Ownership
- Exception

- Change Management

86. Governance API

주요 API 범주:

- Policy API
- Approval API
- Risk API
- Review API
- Exception API
- Evaluation API
- Change API
- Ownership API

예:

POST /governance/reviews

GET /governance/reviews/{id}

POST /approvals

POST /approvals/{id}/approve

POST /governance/exceptions

GET /governance/exceptions

실제 Endpoint는 API Specification 확장 단계에서 최종 확정한다.

87. Governance Event

주요 Event:

- GovernanceReviewRequested
 - GovernanceReviewCompleted
 - ApprovalRequested
 - ApprovalGranted
 - ApprovalRejected
 - PolicyActivated
 - PolicyChanged
 - ExceptionCreated
 - ExceptionExpired
 - RiskChanged
 - ResourceBlocked
-

88. Governance Data Retention

Governance Decision과 Approval은 운영 및 감사 필요성에 따라 일반 Log보다 긴 Retention을 가질 수 있다.

88.1 삭제

Retention 종료 후 삭제하더라도 최소 법적·운영상 필요한 기록 정책을 따를 수 있도록 한다.

89. Governance Privacy

Governance Dashboard와 Audit에서 불필요하게 Tenant Content를 노출하지 않는다. Review에는 필요한 Metadata와 Evidence만 제공하는 것을 원칙으로 한다.

90. Governance Testing

다음 테스트를 수행해야 한다.

90.1 Policy Test

Permit / Deny 조건이 의도대로 동작하는지 검증한다.

90.2 Approval Test

Approval 없는 고위험 Action이 차단되는지 확인한다.

90.3 Exception Test

Exception 범위를 벗어난 Action이 허용되지 않는지 확인한다.

90.4 Version Test

이전 Policy와 신규 Policy가 구분되는지 검증한다.

90.5 Risk Test

Risk Level 변경에 따라 Gate가 달라지는지 확인한다.

90.6 Permission Expansion Test

Resource Update가 권한을 확대하면 Review가 발생하는지 검증한다.

90.7 Emergency Control Test

Kill Switch와 Block 정책이 즉시 적용되는지 확인한다.

91. Governance Regression Test

다음 변경은 Regression Test 대상이다.

- Policy Engine
- Risk Rule
- Approval Rule
- Model Routing Policy
- Plugin Admission
- Agent Autonomy Policy

91.1 Golden Scenario

핵심 Governance 시나리오에 대해 Expected Decision을 유지할 수 있다.

92. Governance Acceptance Criteria

AGEX Governance는 운영 적용 전에 최소한 다음을 충족해야 한다.

1. 모든 중요 Resource에 Owner를 지정할 수 있다.
2. Risk Level을 정의할 수 있다.
3. Risk에 따라 Approval을 요구할 수 있다.
4. Agent Autonomy Level을 통제할 수 있다.
5. Policy가 Versioned Resource로 관리된다.
6. Policy Simulation이 가능하다.
7. Permission 확대를 식별할 수 있다.
8. Resource Promotion Gate가 존재한다.
9. Model Admission 절차가 존재한다.
10. Plugin Admission 절차가 존재한다.
11. Knowledge 및 Memory 승격 규칙이 존재한다.
12. 비용 Budget을 적용할 수 있다.
13. Quality Gate를 적용할 수 있다.
14. Exception이 공식 Resource로 관리된다.
15. Exception Expiration을 지원한다.
16. Governance Decision을 Audit할 수 있다.
17. Emergency Kill이 가능하다.
18. Tenant별 Governance 설정이 가능하다.
19. Platform Baseline을 Tenant가 약화시킬 수 없다.
20. Runtime이 최종 Governance Decision을 집행할 수 있다.

93. Governance 금지사항

다음 구조는 허용하지 않는다.

- Owner 없는 Critical Resource의 Production 운영
- Agent가 자신의 Autonomy Level을 변경
- Model이 자신의 사용 권한을 결정
- Permission 확대를 일반 Patch로 Silent 적용
- High-Risk Plugin의 검토 없는 Production 사용
- Security Baseline보다 약한 Tenant Policy
- 승인 Payload 변경 후 기존 Approval 재사용
- 만료 없는 Security Exception을 기본값으로 사용
- Resource Publish 이후 Definition 직접 수정
- Quality Regression을 숨기고 신규 Version 자동 Promotion
- Cost Budget을 Agent가 임의 변경
- Blocked Model 또는 Plugin을 Fallback으로 사용
- Marketplace Rating을 Security Certification으로 간주
- Memory를 자동 공식 Knowledge로 승격
- Policy 변경 이력 미관리
- 관리자 Override의 무감사 수행
- Emergency Block 해제를 무승인 수행
- Governance Rule을 UI 코드에만 구현
- Production과 SDK/CLI에 서로 다른 Governance 규칙 적용
- 사후 Audit만으로 Governance를 대체

94. Governance 검증 기준

새로운 AGEX 기능이나 Resource는 다음 질문을 통과해야 한다.

1. Owner는 누구인가.
2. Risk Level은 무엇인가.

3. 누가 생성할 수 있는가.
4. 누가 수정할 수 있는가.
5. 누가 승인할 수 있는가.
6. 어떤 상태에서 실행 가능한가.
7. Permission이 증가할 수 있는가.
8. Human Approval이 필요한가.
9. Quality를 어떻게 평가하는가.
10. Cost를 어떻게 제한하는가.
11. 어떤 Policy가 적용되는가.
12. Policy Version을 기록하는가.
13. Data Classification은 무엇인가.
14. 외부 Provider를 사용하는가.
15. Exception이 가능한가.
16. Exception은 만료되는가.
17. Emergency Block이 가능한가.
18. 모든 결정이 Audit되는가.
19. Tenant가 Baseline을 약화시킬 수 있는가.
20. Runtime에서 실제로 집행 가능한가.

95. Governance의 최종 정의

AGEX Governance는 AI Resource와 AI 실행이 기술적으로 가능하다는 이유만으로 자동 허용되지 않도록, 모든 Agent·Workflow·Model·Plugin·Knowledge·Memory·Runtime의 생성, 승인, 배포, 실행, 변경 및 종료를 책임·정책·위험·품질·비용 기준으로 통제하는 AI Operating System의 관리 체계이다.

AGEX에서 AI의 자율성은 Governance의 부재를 의미하지 않는다.

Agent의 Autonomy Level은 Platform과 Tenant 정책에 의해 설정되며 Agent 자신이 확

대할 수 없다.

Production Resource는 Owner, Version, Risk, Evaluation 및 필요한 Approval을 가져야 하며 고위험 Resource는 강화된 Review와 Separation of Duties를 적용할 수 있다.

Model은 Provider Trust, 데이터 등급, 품질, 비용, Region 및 Tenant Policy를 기준으로 승인되며 Provider가 신규 Model을 공개했다고 자동으로 운영에 사용하지 않는다.

Plugin과 Marketplace Package는 Publisher, Permission, Network, Side Effect, Security 및 Supply Chain을 평가하여 승인된 범위에서만 사용한다.

Knowledge와 Memory는 서로 다른 Governance Domain으로 관리하며 Memory가 공식 Knowledge가 되기 위해서는 Source와 Confidence 검증을 거쳐야 한다.

Policy는 Versioned Resource이며, 실제 Execution에는 어떤 Policy Version과 Approval이 적용되었는지 추적할 수 있어야 한다.

예외는 비공식 설정 우회가 아니라 명시적인 Exception Resource로 관리하며 Owner, Risk, 승인자, 보완 통제 및 Expiration을 가져야 한다.

Governance는 단순한 사후 Audit이 아니라 AI가 무엇을 할 수 있고, 무엇을 해도 되며, 누가 그 결정에 책임지는지를 실행 전에 결정하는 체계이다.

AGEX Governance는 다음 문장으로 최종 정의한다.

AGEX Governance는 AI의 자율성을 억제하는 절차가 아니라, 자율성이 책임·정책·위험·품질·비용이라는 명확한 경계 안에서 신뢰 가능하게 작동하도록 만드는 AI Operating System의 최상위 통제 체계이다.

본 문서는 AGEX 전체 Resource와 실행의 Ownership, Risk, Approval, Policy, Quality, Cost, Exception, Change 및 책임 체계를 규정하는 공식 Governance 문서로 사용한다.